

# Controls and compliance checklist

## Controls assessment checklist

| Yes                                 | No                                  | Control                                                             |
|-------------------------------------|-------------------------------------|---------------------------------------------------------------------|
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Least Privilege                                                     |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Disaster recovery plans                                             |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Password policies                                                   |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Separation of duties                                                |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Firewall                                                            |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Intrusion detection system (IDS)                                    |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Backups                                                             |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Antivirus software                                                  |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Manual monitoring, maintenance, and intervention for legacy systems |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Encryption                                                          |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Password management system                                          |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Locks (offices, storefront, warehouse)                              |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Closed-circuit television (CCTV) surveillance                       |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Fire detection/prevention (fire alarm, sprinkler system, etc.)      |

---

## Compliance checklist

### Payment Card Industry Data Security Standard (PCI DSS)

| Yes                      | No                                  | Best practice                                                                                                |
|--------------------------|-------------------------------------|--------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Only authorized users have access to customers' credit card information.                                     |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Implement data encryption procedures to better secure credit card transaction touchpoints and data.          |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Adopt secure password management policies.                                                                   |

### General Data Protection Regulation (GDPR)

| Yes                                 | No                                  | Best practice                                                                                                     |
|-------------------------------------|-------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | E.U. customers' data is kept private/secured.                                                                     |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. |
| <input type="checkbox"/>            | <input checked="" type="checkbox"/> | Ensure data is properly classified and inventoried.                                                               |
| <input checked="" type="checkbox"/> | <input type="checkbox"/>            | Enforce privacy policies, procedures, and processes to properly document and maintain data.                       |

### System and Organizations Controls (SOC type 1, SOC type 2)

| Yes                      | No                                  | Best practice                                      |
|--------------------------|-------------------------------------|----------------------------------------------------|
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | User access policies are established.              |
| <input type="checkbox"/> | <input checked="" type="checkbox"/> | Sensitive data (PII/SPII) is confidential/private. |

- |                                     |                          |                                                                                            |
|-------------------------------------|--------------------------|--------------------------------------------------------------------------------------------|
| <input checked="" type="checkbox"/> | <input type="checkbox"/> | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| <input checked="" type="checkbox"/> | <input type="checkbox"/> | Data is available to individuals authorized to access it.                                  |
- 

### **Recommendations:**

- Establish a legacy system decommissioning or upgrading plan.
- Implement Role-Based Access Control (RBAC) based on the Principle of Least Privilege and Separation of Duties.
- Enforce strong encryption for PII/SPII data both at rest and in transit, and strictly prohibit unsecured local storage of cardholder data to comply with PCI DSS.
- Deploy Intrusion Detection System (IDS) to monitor internal network traffic and detect anomalous behavior.
- Develop a comprehensive Disaster Recovery Plan and implement a regular, automated, and tested data backup schedule.
- Upgrade the password policy complexity requirements and deploy a Centralized Password Management System to enforce compliance and streamline vendor/employee password recovery.
- Define a regular, structured monitoring and maintenance schedule for all critical and legacy systems, establishing clear incident response and intervention protocols.